Detection of Payload-Free Pretexting Emails Through Claim-Routed Verification Against Email Headers and Thread History

[Author 1 name]*
[Department]
[Organisation]
[City, Country]
[email address]

[Author 2 name]
[Department]
[Organisation]
[City, Country]
[email address]

***Abstract*—Pretexting emails often carry no link and no attachment, and a sender who writes from a free mailbox or a lookalike domain passes SPF, DKIM and DMARC for that domain. This paper describes a claim-routed verification pipeline that extracts typed claims from the body and routes each one to the header or thread rules that can test it. Every verdict is a ledger row naming the claim, the rule and the evidence, so each of the 442 test emails the pipeline flagged has a stated reason. On synthetic takeover replies injected into real threads, the thread rules detect 18 of 25 Apache and 48 of 51 Enron cases, against 5 and 0 for the header and request rules alone. A payload-free protocol, run on corpus labels with one training sample and two seeds, shows that a detector trained on raw text owes part of its accuracy to reading links: under link redaction its F1 drops by 0.073 more than that of a model trained on redacted text, with a bootstrap interval from 0.061 to 0.086. The pipeline is not the best pooled detector. On 3,045 test attacks and 6,357 legitimate emails its F1 is 0.238, against 0.882 for parallel fusion of text and header classifiers, and its AUC is the lowest of five systems.**

Keywords—business email compromise, pretexting, phishing detection, email authentication, claim verification, thread hijacking

I. Introduction

Business email compromise (BEC) is pretexting aimed at money: the attacker poses as a trusted person, such as an executive or a supplier, and asks for a payment, a change of bank details or data. In 2025 the Internet Crime Complaint Center of the FBI recorded 24,768 BEC complaints and $3,046,598,558 in reported losses [1]. The 2026 Data Breach Investigations Report defines pretexting as building a trusted relationship through invented scenarios, by voice, email or text, with the attacker taking part in the conversation or email thread, and finds it to be the initial access vector in 6% of breaches [2].

Such emails can be payload-free: they carry no link and no attachment, so scanners built around URLs and attachments find nothing. Consider a message signed by David from Finance that asks an accounts clerk at acmecorp.com to process a wire transfer before 3 PM and to tell no one. It comes from a real gmail.com account, so SPF [3], DKIM [4] and DMARC [5] all pass, but only for gmail.com. Authentication proves which domain sent a message; it says nothing about whether the sender is the person or the organisation the body claims. The attack is only visible as a disagreement between claims of body and headers.

Detectors that could see this disagreement mostly look elsewhere. Work on phishing from compromised accounts focuses on emails with a malicious URL, and its authors note that their data likely underestimate attacks without one [6]. BEC-Guard judges impersonation from an organisation's header history and classifies the body only after removing names and signatures [7], so the statements that say who is writing are never compared with the headers. ChatSpamDetector asks GPT-4 to look for brand impersonation and header spoofing, which covers part of this comparison, but its data exclude emails without a URL and each email costs one model call [8].

We treat the problem as fact-checking. Automated fact-checking divides the task into claim detection, evidence retrieval and claim verification, which gives a verdict and its justification [9]. Here the claims are what an email says about itself and the evidence is its own headers and, for a reply, the earlier messages of its thread. A claim to be a colleague is checked against the authenticated domain, a payment request against who is asking, and a reply against the history it joins. An account that has been taken over passes every header check, so against that attacker the thread is the only evidence left.

The paper makes four contributions. 1) The claim-routed verification pipeline, in which typed claims are routed to the header, request or thread rules that can test them and every finding is a ledger row naming the claim, the rule and the evidence. 2) A payload-free evaluation protocol, N1, which redacts links, addresses, domains and file names and measures how much of a detector's accuracy comes from reading links. 3) Thread consistency verification, N2, which compares a reply with its own thread. 4) An evaluation with frozen components, a test log, grouped bootstrap intervals and results per source, which also shows that the pipeline is not the best pooled detector on public corpora.

II. Related Work

Persuasion and tactics. Persuasion is measurable in email text. Karki et al. tag persuasion principles in phishing emails with transformer classifiers and report an average F1 of 0.9 for RoBERTa on five principles, with labels produced automatically by sentence similarity to manually written examples [10]. Tooher and Lallie detect phishing from persuasion principles in two stages and report 94% accuracy, but their phishing emails were generated by a language model and labelled by design while their legitimate emails are real [11]; in such a set, writing style alone can separate the classes. Across seven public corpora, Pan et al. find every persuasion principle more often in phishing than in legitimate mail, yet authority cues still appear in 27.10% of legitimate samples, and the authors note that targeted attacks such as BEC may not be represented in such corpora [12]. These studies read the body only. In the pipeline a tactic is a modifier: it raises the weight of a contradiction and never creates one.

Identity from metadata and history. BEC-Guard first decides from an organisation's header history whether a sender impersonates an employee and only then classifies the body and its links, after removing names and signatures from

*Corresponding author.

the text; it reports a precision of 98.2% on more than 4,000 attacks, and account takeover is outside its focus [7]. Gascon et al. profile senders from the structure and transport traits of their emails without reading the text, detecting 90% of spoofed emails at fewer than one false alarm in 10,000; they note that such infrastructure features model the sender's environment rather than the author, so a hacked account cannot be detected with them [13]. These systems ask whether an email fits its sender's history. The pipeline asks whether what the email claims matches its own headers, needs no mail history beyond the thread being checked, and looks for account takeover in the thread itself. We did not find an academic detector of thread hijacking with an open evaluation.

Claims and model judgement. Paul et al. annotate 940 emails with the warning signs that users are trained to notice, among them the organisation a sender claims, and train a classifier for each sign; they observe that a mismatch between such a claim and the metadata is often a stronger signal than the content, and assume a downstream verification algorithm for that comparison [14]. The pipeline is an example of such an algorithm. ChatSpamDetector has been reported to achieve 99.70% accuracy on 2,010 emails using a GPT-4 prompt to test for a name mismatch in the sender field [8]. As a result, this paper does not lay claim to be the first to validate the sender name against the headers. ConvoSentinel is another example and classifies social engineering attempts at a message or conversation level on 1,400 synthetically generated conversations [15]. It does not use the header and thread metadata that email provides. The pipeline is different in that it validates the claims an email makes using fixed rules and records the reasoning, and does not use a model at run time. Last, the pipeline is evaluated on redacted text and emails that do not contain clickable links.

III. Problem and Threat Model

An email is considered payload-free when it carries neither a link nor an attachment. The only malicious thing in the email is the text, which instructs the receiver to perform an action. The defending organization is the receiving organization. The input is an email or email thread, where the organization's email domain is known; or, where it is not known, checks that need it are documented as not checkable (guessed checks are not performed).

Attacks from the outside. Free mailboxes, lookalike domains, and spoof domains all provide an attacker with a means to send mail that appears to come from someone else. An attacker using a free mailbox or lookalike domain will often impersonate someone by setting a display name and choosing a Reply-To address to mislead. With a free mailbox or a lookalike domain, the email comes from the attacker's own domain and as such, will pass SPF, DKIM and DMARC for that domain; a spoof of the organization's own domain fails DMARC, if the organization has published a DMARC policy. If the body of the email claims a relationship to the organization, the header rules (N3) check whether the headers support that relationship.

Attacker inside a real account. After a successful takeover or compromise of a vendor or thread hijack, email is sent from a real domain and as such, will pass authentication. The email may impose a sense of urgency, provide new banking information, or arrive through a new sending path (a different server or mail program). The thread rules (N2) look for these sorts of alterations to a thread, and also test a forged thread that quotes a conversation that never happened.

Trust in headers. Except for headers added by the receiving side, all headers are written by the sender and are not trusted. Only Authentication-Results fields added by the receiving organization are trusted, as stated in RFC 8601 [16]. The pipeline reads their verdicts and does not compute them. A missing verdict is unknown, never a pass. Out of scope is an attacker who has read the email box and copies the reply identifiers, sending details and a calm tone of the real sender. No rule in this pipeline can detect that message.

IV. The Claim-Routed Verification Pipeline

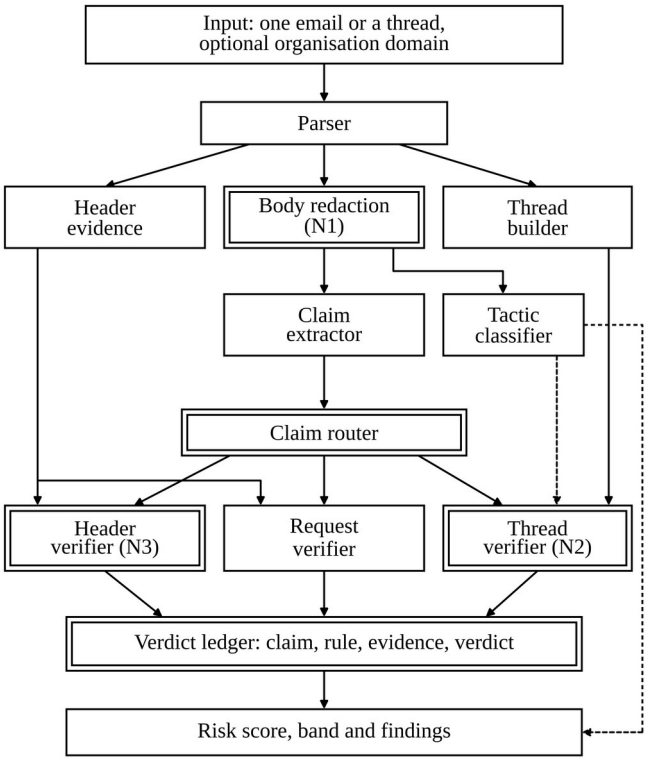


Fig. 1. The claim-routed verification pipeline. Double borders mark the parts introduced here; the dashed line carries tactic probabilities to the thread verifier (tactic onset) and to the score (urgency and secrecy as modifiers).

Fig. 1 shows the entire pipeline. A parser splits each message into headers, body and thread links and three branches follow it: header evidence, body redaction and for a thread, a thread builder that orders the messages and keeps each's quoted history.

A. Redaction, Claims and Tactics

The cleaned body is redacted before any model or rule reads it: URLs, email addresses, bare domains and attachment file names become the placeholders [URL], [EMAIL], [DOMAIN] and [FILE], while words such as *see attached* stay. A claim extractor built from a tokenizer, a name recogniser and 85 token patterns reads the redacted text and its signature block; nothing in it is trained. It emits typed claims with a text span: internal or external affiliation, authority, reply direction and signature contact; prior relationship; and five request types (payment, payment change, credential, gift card, data). Beside the extractor, a tactic classifier gives probabilities for seven tactics: authority, scarcity, reciprocity, social proof and liking from the persuasion literature [17], urgency from the time principle [18], and isolation or secrecy.

B. Routing and Verification

The router sends affiliation, authority, reply direction and signature claims to the header verifier, a claim of a prior relationship to the thread verifier, and each request to the

request verifier and, when a thread is present, also to the thread verifier. Tactics go to no verifier, because no header can prove or disprove urgency.

The header verifier (N3) compares three domains: the From domain the reader sees, the domain that authentication vouched for and the domain the claim implies, which is the organisation's own domain or a known brand's domains. A contradiction is a mismatch that the claim makes meaningful, so the same header values mean different things under different claims: dmarc=pass for gmail.com is normal for a private Gmail user and a contradiction of high severity under *this is David from Finance*. The request verifier asks who is asking: a free mailbox outside the organisation, a lookalike sender, a failed DMARC check or a Reply-To to another domain. A change of bank details can never be confirmed by headers and is left to the thread.

The thread verifier (N2) judges each message against the messages before it on four signals: tactic onset, where a tactic crosses its threshold for the first time and well above its earlier average; request drift, such as new bank details or a first credential request; sending path drift, such as the same address from a new network and mail program or the sender's name at a lookalike domain; and thread integrity, where reply identifiers point to no earlier message or quoted text never appeared in the thread. The first message with medium to high contradiction is reported as the place where the thread has flipped.

C. Verdict Ledger and Risk Score

Each ledger row contains a claim, rule, evidence, reason and a verdict of contradiction with a severity of high, medium or low; consistent; or not checkable. When the evidence is lacking, the verdict is not checkable, and only contradictions add to the score. A high severity contradiction is worth 60 points, a medium one 35 points, while a low severity contradiction is worth 5 points; the strongest contradiction of a claim is counted, and subsequent contradictions of the following claims are counted at 50% and 25% respectively. Three rules that fire often on legitimate mail are scored zero. There are four main tactics. Urgency and secrecy each increase the multiplier on these points by 0.25 and the four main tactics increase the score by 4 each. These are capped at 12 points, which doesn't reach the Suspicious band at 35; High risk starts at 70. The weights were fixed on the validation data before the test split was read. Table I traces the example of Section I.

TABLE I. LEDGER FOR THE EXAMPLE OF SECTION I

Claim and span	Verifier	Evidence	Row
affiliation_internal "this is David from Finance"	header	From gmail.com, a free mailbox; authenticated as gmail.com; organisation acmecorp.com	contradiction, high hv_int_freemail 60 points
payment_request "process a wire"	request	payment request from a free mailbox outside acmecorp.com	contradiction, high rv_freemail +30 points

Score 90, High risk, before any tactic points. The Reply-To to protonmail.com appears in the findings but adds no row, because the body makes no claim about where replies should go.

The complete pipeline is written in Python. The tactic classifier is a DistilBERT model [19], fine-tuned on the labelled real and synthetic train emails of Section V, and thresholds are set on the validation data. Language models are not run during analysis. An email is kept in memory only for the duration of the analysis.

V. EVALUATION DESIGN

The evaluation follows the pitfalls listed by Arp et al. [20]: the test split was frozen before it was read, results are reported per source and a separate test measures how far the collections differ by wording alone.

A. Data and Labels

Nine public sources provide 99,324 unique emails, 20,313 of which are attacks: phishing from the Nazario corpus [21] and honeypot collections [22], fraud emails, legitimate emails and spam from the CEAS-08, Enron [23], Ling and Nigerian Fraud files of a merged corpus [24], SpamAssassin public corpus [25], and Apache user lists [26] as modern legitimate emails with authentication. The split is 70/15/15 by source and category, and emails of a single subject are kept together. There are 69,542 train, 14,879 validation, and 14,903 test emails. No source contains both attacks and legitimate emails, so a pooled assessment combines both corpus and detection, and results are provided by source.

Real threads were rebuilt by subject, date and by participants from the raw Enron corpus and by reply identifiers from the Apache lists (1,591 threads, split by thread). Each of the test base threads has a synthetic message replacing the next real reply with one of three variations (A, B and C). Variation A is an account takeover; the text drifts, while the sender, server, mail program and reply identifiers are copied from the real sender. Variation B is a 'lookalike' domain swap with neutral or benign content and a new sending path (variant only for Apache, as the raw Enron corpus doesn't include sending path information). Variation C is a forged thread with a fabricated quotation and with (for Apache) unknown reply identifiers. The negatives are the real next reply, and a synthetic benign continuation. The injected contents were generated with language models of one family.

For the tactics and claims, 700 real emails were drawn, a fixed number per source and category. Two language model annotators from one model family labelled seven tactics and eleven claim types, and a third model of the same family broke ties; 690 emails were labelled, 140 of them in the test split. Mean Cohen's kappa between the two annotators was 0.501 over the tactics and 0.458 over the claim types. No human labels were collected, although LLM labels need validation against human labels task by task [27], so every tactic or claim score is agreement with one model family. 222 synthetic pairs, each an attack and a benign twin, cover rare tactics and are reported apart.

B. Experiments

Payload-free protocol (N1). Two DistilBERT models separate attacks (phishing, fraud) from other mail (ham, spam): model A is trained on raw bodies and model B on redacted bodies, from one training sample of 9,856 emails with two seeds and a fixed threshold of 0.5. A TF-IDF and logistic regression pair, fitted on the same sample and on all train emails, is a second family. Each model is tested on the raw and redacted views of the test split and on the test emails that never had a link. The quantity of interest is A's drop in F1 on the attack class from raw to redacted, minus B's drop: a model that reads links as a shortcut [28] loses more when they are removed. The labels are corpus labels.

Thread consistency (N2). The thread verifier is compared with the header and request verifiers alone on the test cases; a case is detected when the injected message receives a medium or high contradiction.

Claim conditioning (N3) and architecture. The frozen routed score, flagging at Suspicious or above, is compared with four logistic regressions fitted on the train split, attack against ham: text only (tactic probabilities and claim counts), headers only (authentication verdicts, free mailbox, lookalike, Reply-To and similar fields), parallel fusion (the mean of the text and headers scores) and a flat classifier given every ledger signal as one vector without the link between a claim and its evidence. Each learned system is held to the false alarm rate the frozen score shows on validation ham, 0.14%, with a floor of 0.5%. A synthetic arm adds 31 pairs in which a colleague is impersonated, with header blocks written by rule: the attack comes from a free mailbox or a lookalike domain that passes its own authentication, and its twin from the organisation's own domain.

C. Protocol

Before the first test run a freeze record stored a SHA-256 hash of every frozen file (the patterns, the rules, the score weights, the model weights and the thresholds), and every script refused to read the test split if one differed. Every script was rehearsed on the validation split before it read the test split, and every test run is logged. Intervals are 95% percentile intervals from 1,000 bootstrap resamples that draw whole groups (subject groups for emails, threads for hijack cases, pairs for synthetic emails), and differences between systems are paired. Cells with fewer than 10 positives are reported as counts.

VI. Results

TABLE II. Main Results on the Test Split

(a) Pooled detection: 3,045 attacks against 6,357 ham

System	F1 [95% interval]	Recall	FAR	AUC
Routed score	0.238 [0.204, 0.277]	13.6%	0.3%	0.812
Text only	0.639 [0.612, 0.666]	47.4%	0.5%	0.949
Headers only	0.788 [0.767, 0.810]	65.5%	0.3%	0.966
Parallel fusion	0.882 [0.869, 0.895]	80.3%	0.8%	0.993
Flat classifier	0.658 [0.629, 0.687]	49.7%	0.5%	0.949

(b) Synthetic messages in real threads: cases flagged

Case	Source	Cases	Thread rules	Header and request rules
A, takeover	Apache	25	18	5
A, takeover	Enron	51	48	0
B, lookalike swap	Apache	17	17	0
C, forged thread	Apache	25	25	0
C, forged thread	Enron	51	45	0
Real next reply	Apache	25	0	0
Real next reply	Enron	51	1	0

(c) Links: DistilBERT F1 on the attack class; corpus labels; 9,856 training emails, two seeds

Model	Raw	Redacted	Raw minus redacted
A, trained on raw	0.935	0.877	+0.059 [+0.050, +0.069]
B, trained on redacted	0.918	0.932	−0.014 [−0.019, −0.009]
A's drop minus B's drop			+0.073 [+0.061, +0.086]
Same, TF-IDF, sample			+0.035 [+0.025, +0.046]
Same, TF-IDF, all train			+0.028 [+0.021, +0.037]

FAR: false alarm rate on ham. Learned systems are held to the routed score's validation false alarm rate with a 0.5% floor. Intervals: 1,000 resamples of whole subject groups or threads.

A. Pooled Detection

Table II(a) compares the routed score with four learned systems that use the same information. On 3,045 test attacks against 6,357 test ham it detects fewer attacks than any of them: its F1 is 0.238 [0.204, 0.277] and its recall 13.6%, against an F1 of 0.639 for text only, 0.788 for headers only, 0.882 for parallel fusion and 0.658 for the flat classifier. All four paired differences in F1 lie below 0; routed minus fusion is −0.644 [−0.678, −0.605]. The AUC, which needs no cut, is also the lowest (0.812 against 0.949 to 0.993). Three things limit this comparison and none removes the gap: the learned systems were fitted on attack labels and the routed score uses none, a model of the headers alone can partly learn which corpus an email came from, and the 0.5% floor lets each learned system flag more validation ham than the routed score does. Table III gives the rates per source. The attack sources differ in their header evidence: headers only detects 99.5% of the phishing_pot attacks but 2.5% of the Nigerian fraud emails, whose original headers were not kept, while the routed score detects 7.4%, 15.3% and 22.8% of the phishing_pot, Nazario and Nigerian fraud attacks. On the ham of every source all five systems flag at most 3.1%; spam, which no system was fitted on, is flagged at up to 25.5% (SpamAssassin, headers only) and at most 4.0% by the routed score.

TABLE III. Share Flagged per Source on the Test Split

Source	Emails	Routed	Text	Headers	Fusion	Flat
Nigerian fraud	486	22.8%	46.1%	2.5%	74.3%	52.9%
Nazario	1,439	15.3%	58.9%	60.4%	83.9%	58.3%
phishing_pot	1,120	7.4%	33.2%	99.5%	78.3%	37.1%
Apache Kafka (ham)	158	1.3%	0.0%	0.0%	0.0%	0.0%
Apache Tomcat (ham)	324	0.0%	0.0%	0.0%	0.0%	0.0%
CEAS-08 (ham)	2,588	0.6%	0.4%	0.0%	1.6%	0.3%
Enron (ham)	2,313	0.0%	0.8%	0.0%	0.0%	1.0%
Ling (ham)	359	0.0%	0.3%	0.0%	0.0%	0.3%
SpamAssassin (ham)	615	0.0%	0.3%	3.1%	1.5%	0.5%
CEAS-08 (spam)	3,126	0.0%	2.1%	0.1%	10.2%	2.0%
Enron (spam)	2,055	0.0%	8.6%	0.0%	0.0%	8.0%
Ling (spam)	69	0.0%	7.2%	0.0%	0.0%	7.2%
SpamAssassin (spam)	251	4.0%	12.3%	25.5%	24.7%	15.5%

First three rows: attacks detected. Ham rows: false alarms. Spam rows: share flagged; no system was fitted on spam. The learned systems are held to the routed score's validation false alarm rate with a 0.5% floor.

Because only contradictions can lift an email to Suspicious, the routed score can flag only emails with a checked claim, and 788 of the 3,045 test attacks have one (398 of the 6,357 ham). On these emails its F1 is 0.679 [0.633, 0.734]. It is not distinguishable from text only (difference −0.063 [−0.136, +0.026]) or headers only (−0.057 [−0.119, +0.003]), remains behind parallel fusion (−0.260 [−0.305, −0.211]) and the flat classifier (−0.174 [−0.214, −0.135]), and has a higher false alarm rate on that ham than text only or headers only (4.3% against 1.5% and 0.5%).

Every email the routed score flagged has a claim, a rule and evidence behind it (442 of 442); none of the flat classifier's 1,819 flags names a claim. This is a property of the design, not a measured gain. On the 31 synthetic impersonation pairs the routed score flagged 19 attacks (61.3% [45.2%, 77.4%]) and 0 twins. Headers only flagged all 31 attacks and all 31 twins, parallel fusion 17 attacks and 4 twins, the flat classifier 17 and 0, and text only 11 and 0. The text and the headers of this arm are synthetic.

B. Thread Consistency

On variant A, which changes only the content, the thread rules detect 18 of 25 Apache cases (72.0% [52.0%, 88.0%]) and 48 of 51 Enron cases (94.1% [88.2%, 100.0%]), against 5 of 25 and 0 of 51 for the header and request rules alone (Table II(b)). Variants B and C each change one thing the rules are defined to check, so detecting them mainly confirms that the rules work as specified. When the whole thread is scanned, the first contradiction falls on the injected message in 17 of 25 Apache and 40 of 51 Enron takeover cases. The thread rules flagged 0 of 25 real next replies on Apache and 1 of 51 on Enron. On all real, unmodified test threads they raised a medium or high contradiction on 4.44% [3.08%, 5.99%] of 698 Enron messages with earlier messages, 0.50% of 201 Tomcat messages and 0.00% of 95 Kafka messages. The injected messages and their headers are synthetic, so these

rates test the rules against the construction rather than against real attackers.

C. Payload-Free Protocol

With corpus labels and one training sample of 9,856 emails and two seeds, model A loses F1 on the attack class when links are redacted at test time (raw minus redacted +0.059 [+0.050, +0.069]); model B does not (−0.014 [−0.019, −0.009]). A's drop minus B's drop is above 0 in all three families (Table II(c)), so a detector trained on raw text owes part of its accuracy to reading links. The loss sits in the phishing sources. A's recall falls from 94.5% to 75.7% on phishing_pot and from 94.1% to 86.0% on Nazario when links are redacted, and stays at 99.4% on Nigerian fraud, while B reaches 94.3% and 93.9% on the redacted phishing_pot and Nazario attacks. B on redacted text scores 0.932, against 0.935 for A on raw text, so training on redacted bodies keeps most of the accuracy. On the 696 test attacks that never had a link the two DistilBERT models are not distinguishable (0.863 [0.840, 0.884] and 0.862 [0.839, 0.884]), but that subset is a different mix of sources, so its F1 does not compare the same emails before and after redaction. A rule that flags every email with a link reaches an F1 of 0.413, with a false positive rate of 46.5% on ham.

D. Tactics, Claims and Score Budget

On the 140 labelled test emails, whose labels come from one model family, the tactic classifier's macro F1 over authority, urgency, scarcity and secrecy is 0.479 [0.370, 0.574], against 0.500 [0.408, 0.581] for a keyword baseline with thresholds tuned on validation; the paired difference, −0.021 [−0.144, +0.091], includes 0, so neither is better. Per tactic the point estimates favour DistilBERT for authority (0.526 against 0.167, 25 positives) and the baseline for scarcity (0.436 against 0.632, 26) and secrecy (0.381 against 0.645, 16), and are close for urgency (0.574 against 0.557, 44). The claim extractor's macro F1 over the five claim types with at least 10 positives in both validation and test is 0.568 [0.470, 0.646]. Its strongest type is authority (0.718 [0.526, 0.870]) and its weakest internal affiliation (F1 0.250 [0.000, 0.533], 2 of 12 found), on which the two annotators agree with each other at an F1 of only 0.410. The frozen score stayed within its false alarm budget (High risk for at most 1% and Suspicious or above for at most 5% of checked legitimate mail per source) in 4 of 5 groups with at least 20 checked emails. CEAS-08 ham was over, at 5.60% of 268 checked emails, with an interval [3.42%, 9.03%] that still includes the budget.

VII. Discussion and Limitations

The results support the payload-free protocol, the thread checks and the traceability of alarms, within the limits below. They do not support the expectation that checking claims against their evidence detects more attacks than simpler uses of the same information. On these corpora it detects fewer.

Tactic and claim scores are agreement with LLM labels from one model family; the N1 labels are corpus labels. No source holds both attacks and ordinary mail, so every pooled number mixes corpus and detection. The collections also differ by wording alone. Real and synthetic attack emails are separated by their words with an AUC of 1.000 [1.000, 1.000] (90 real and 31 synthetic test emails), which is why they are reported apart, and even two sources of the same kind are separated by their words, with a median AUC of 0.996 over 24 such pairs. The learned comparators saw attack labels, and a model of the headers alone can partly learn which corpus an email came from. Both favour the learned systems. The hijack cases, the synthetic header blocks and the paraphrases were produced by a language model or by rule, so they show that the rules do what they are defined to do, not how often real attackers behave that way. N1 rests on one training sample and two seeds, so its intervals cover the test sample and not the training randomness. Rewording 144 attack bodies with a language model kept 18 of the 24 flags they started with and added 6 among the 120 not flagged before, and the ham control gained 1 flag among 59; but the headers were untouched, so a header contradiction survives by construction, and meaning was checked on six pairs only. Checks of internal affiliation need the organisation's domain, which most public corpora do not reveal, and the extractor reads English only. An attacker who copies the identifiers, the sending details and the tone of a real thread is not caught by any rule here.

VIII. Conclusion

One checks what an email claims against its headers and thread to find that each alarm has a stated reason, and finds synthetic takeover replies in real threads, which the header and request rules miss. However, on pooled detection over public data sets, the routed score is lower than all four learned classifiers, hence the design does not detect additional attacks on the data on its own. Redacting links is cheap and removes a shortcut. The real test of the design is on actual attacks. This requires that there be a labelled sample of payload-free BEC emails (or other emails passed off as legitimate by an attacker) along with real hijacked threads which retain authentication headers and emails which have been labeled by people for tactics and claims.

References

[1] Federal Bureau of Investigation, Internet Crime Complaint Center, "2025 IC3 annual report." Accessed: Oct. 12, 2026. [Online]. Available: https://www.ic3.gov/AnnualReport/Reports/2025_IC3Report.pdf

[2] Verizon, "2026 data breach investigations report," 2026. Accessed: Oct. 12, 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[3] S. Kitterman, "Sender Policy Framework (SPF) for authorizing use of domains in email, version 1," RFC 7208, Apr. 2014, doi: 10.17487/RFC7208.

[4] D. Crocker, T. Hansen, and M. Kucherawy, Eds., "DomainKeys Identified Mail (DKIM) signatures," RFC 6376, Sep. 2011, doi: 10.17487/RFC6376.

[5] T. Herr and J. Levine, Eds., "Domain-based message authentication, reporting, and conformance (DMARC)," RFC 9989, May 2026, doi: 10.17487/RFC9989.

[6] G. Ho et al., "Detecting and characterizing lateral phishing at scale," in *Proc. 28th USENIX Security Symp.*, Santa Clara, CA, USA, 2019, pp. 1273–1290.

[7] A. Cidon, L. Gavish, I. Bleier, N. Korshun, M. Schweighauser, and A. Tsitkin, "High precision detection of business email compromise," in *Proc. 28th USENIX Security Symp.*, Santa Clara, CA, USA, 2019, pp. 1291–1307.

[8] T. Koide, N. Fukushi, H. Nakano, and D. Chiba, "ChatSpamDetector: Leveraging large language models for effective phishing email detection," arXiv:2402.18093, 2024.

[9] Z. Guo, M. Schlichtkrull, and A. Vlachos, "A survey on automated fact-checking," *Trans. Assoc. Comput. Linguistics*, vol. 10, pp. 178–206, 2022.

[10] B. Karki, F. Abri, A. Siami Namin, and K. S. Jones, "Using transformers for identification of persuasion principles in phishing emails," in *Proc. IEEE Int. Conf. Big Data*, Osaka, Japan, 2022, pp. 2841–2848.

[11] P. Tooher and H. S. Lallie, "A two-stage deep learning framework for AI-driven phishing email detection based on persuasion principles," *Computers*, vol. 14, no. 12, Art. no. 523, 2025.

[12] T. Pan, Q. Yang, A. J. Cole, R. Wilson, and D. Woodard, "Psychology of phishing emails: Quantifying persuasion principles and simulating detection with large language models," SSRN preprint 5436577, 2025.

[13] H. Gascon, S. Ullrich, B. Stritter, and K. Rieck, "Reading between the lines: Content-agnostic detection of spear-phishing emails," in *Research in Attacks, Intrusions, and Defenses (RAID)* (Lecture Notes in

Computer Science, vol. 11050). Cham, Switzerland: Springer, 2018, pp. 69–91.

[14] M. Paul, G. Bartlett, J. Mirkovic, and M. Freedman, “Phishing email detection using inputs from artificial intelligence,” arXiv:2405.12494, 2024.

[15] L. Ai et al., “Defending against social engineering attacks in the age of LLMs,” in *Proc. Conf. Empirical Methods Natural Lang. Process. (EMNLP)*, Miami, FL, USA, 2024, pp. 12880–12902.

[16] M. Kucherawy, “Message header field for indicating message authentication status,” RFC 8601, May 2019, doi: 10.17487/RFC8601.

[17] A. Ferreira, L. Coventry, and G. Lenzini, “Principles of persuasion in social engineering and their use in phishing,” in *Human Aspects of Information Security, Privacy, and Trust* (Lecture Notes in Computer Science, vol. 9190), T. Tryfonas and I. Askoxylakis, Eds. Cham, Switzerland: Springer, 2015, pp. 36–47.

[18] F. Stajano and P. Wilson, “Understanding scam victims: Seven principles for systems security,” *Commun. ACM*, vol. 54, no. 3, pp. 70–75, 2011.

[19] V. Sanh, L. Debut, J. Chaumond, and T. Wolf, “DistilBERT, a distilled version of BERT: Smaller, faster, cheaper and lighter,” arXiv:1910.01108, 2019.

[20] D. Arp et al., “Dos and don’ts of machine learning in computer security,” in *Proc. 31st USENIX Security Symp.*, Boston, MA, USA, 2022, pp. 3971–3988.

[21] J. Nazario, “Phishing corpus.” Accessed: Oct. 12, 2026. [Online]. Available: https://monkey.org/~jose/phishing/

[22] rf-peixoto, “phishing_pot: A collection of real phishing samples collected via honey pots,” GitHub repository. Accessed: Oct. 12, 2026. [Online]. Available: https://github.com/rf-peixoto/phishing_pot

[23] B. Klimt and Y. Yang, “The Enron corpus: A new dataset for email classification research,” in *Machine Learning: ECML 2004*. Berlin, Germany: Springer, 2004, pp. 217–226.

[24] A. Al-Subaiey, M. Al-Thani, N. A. Alam, K. F. Antora, A. Khandakar, and S. M. A. U. Zaman, “Novel interpretable and robust web-based AI platform for phishing email detection,” *Comput. Electr. Eng.*, vol. 120, Art. no. 109625, 2024.

[25] Apache SpamAssassin Project, “SpamAssassin public corpus.” Accessed: Oct. 12, 2026. [Online]. Available: https://spamassassin.apache.org/old/publiccorpus/

[26] Apache Software Foundation, “users@kafka.apache.org and users@tomcat.apache.org mailing-list archives.” Accessed: Oct. 12, 2026. [Online]. Available: https://lists.apache.org/

[27] N. Pangakis, S. Wolken, and N. Fasching, “Automated annotation with generative AI requires validation,” arXiv:2306.00176, 2023.

[28] R. Geirhos et al., “Shortcut learning in deep neural networks,” *Nature Mach. Intell.*, vol. 2, no. 11, pp. 665–673, 2020.